



UNIVERSIDAD TECNOLÓGICA DE TEHUACÁN

INGENIERÍA EN DESARROLLO Y GESTION DE SOFTWARE

ASIGNATURA: DESARROLLO WEB PROFESIONAL

8º CUATRIMESTRE GRUPO “A”

MANEJO DE MULTISESIONES Y PERSISTENCIA

PROFR. JOSE MIGUEL CARRERA PACHECHO

LILIA HERNÁNDEZ TUN

¿Qué es una multisesión?

La multisesión es la capacidad de mantener múltiples identidades digitales activas de forma simultánea e independiente en un mismo dispositivo, sin que los datos de una interfieran con la otra.

La multisesión se define por tres pilares:

- **Aislamiento de Perfiles:** Cada sesión funciona como un "recipiente" estanco. Esto significa que las *cookies*, el historial y el almacenamiento local de una cuenta (por ejemplo, un Facebook de un administrador) no son visibles para la otra cuenta abierta en la misma computadora.
- **Huella Digital Única (Fingerprinting):** No solo se separan las cuentas, sino que el sistema hace creer a los sitios web que cada sesión proviene de un dispositivo diferente (cambiando resolución de pantalla, sistema operativo, zona horaria, etc.).
- **Gestión de Proxies:** Permite que cada sesión tenga su propia dirección IP. Así, el servidor ve dos usuarios en lugares distintos, aunque ambos estén en tu laptop.

¿Qué problemas surgen con sesiones concurrentes?

Cuando un sistema permite que un usuario mantenga varias sesiones abiertas al mismo tiempo (o no sabe gestionárselas), aparecen vulnerabilidades y errores de lógica:

1. Inconsistencia de Datos (Race Conditions)

Este es el problema más común. Si el usuario tiene la **Pestaña A** y la **Pestaña B** abiertas:

- En la **Pestaña A** actualiza su perfil (ej. cambia su correo).
- En la **Pestaña B** realiza una compra o una acción sensible.

- **El problema:** Si el sistema no refresca el estado en ambas, la Pestaña B podría estar operando con datos desactualizados o "fantasma", provocando que la base de datos guarde información corrupta o incompleta.

2. Session Fixation (Fijación de Sesión)

Si el sistema no genera un identificador de sesión nuevo y único para cada conexión concurrente, un atacante podría "fijar" un ID de sesión en el navegador de la víctima. Si el usuario inicia sesión legítimamente, el atacante, que ya conoce ese ID, entraría a la cuenta al mismo tiempo sin que el sistema note la diferencia.

3. Falta de Aislamiento de Privilegios

Un error grave ocurre cuando el sistema permite que una sesión de Administrador y una de Usuario Estándar coexistan en el mismo navegador sin aislamiento real. Los datos de sesión (como las cookies) podrían mezclarse, permitiendo que el usuario estándar herede permisos que no le corresponden (*Escalada de Privilegios*).

4. Agotamiento de Recursos (DoS a nivel de Aplicación)

Si no hay un límite de sesiones concurrentes por usuario, un atacante (o un script mal programado) podría abrir miles de sesiones válidas. Esto llena la memoria del servidor o la tabla de sesiones en **PostgreSQL**, dejando al sistema fuera de servicio para los demás.

5. Persistencia de Sesiones "Zombie"

Ocurre cuando el usuario cierra la pestaña, pero la sesión sigue activa en el servidor. En sesiones concurrentes, si el usuario hace "Logout" en el dispositivo A, pero la sesión en el dispositivo B sigue funcionando como si nada, existe un riesgo de seguridad si ese segundo dispositivo cae en manos equivocadas.

¿Cómo se invalida una sesión?

1. Invalidación Explícita (Por código)

- **Cómo ocurre:** Se llama directamente al método de invalidación (comúnmente `invalidate()`) en el objeto de la sesión.
- **Resultado:** La sesión se destruye **inmediatamente**. Esto es lo que sucede cuando el usuario hace clic en el botón de "Cerrar sesión".

2. Invalidación Implícita (Por tiempo de inactividad)

El sistema monitorea cuánto tiempo lleva el usuario sin realizar ninguna acción.

- **MaxInactiveInterval:** Es el tiempo máximo que una sesión puede estar "ociosa" o inactiva antes de ser candidata a ser borrada.
- **El proceso "Reaper" (Segador):** El gestor de sesiones tiene un hilo de ejecución (llamado *reaper thread*) que pasa cada cierto segundo (intervalo X) revisando qué sesiones ya expiraron para eliminarlas.

¿Qué riesgos existen si no se controlan correctamente?

1. Secuestro de Sesión (Session Hijacking)

Si no hay un control estricto (como invalidación por IP o tokens que expiren rápido), un atacante puede robar la *cookie* o el *token* de un usuario legítimo.

- **El Riesgo:** El atacante "clona" la identidad del usuario y entra al sistema sin conocer la contraseña. Si la sesión no tiene un tiempo de vida corto, el atacante tiene acceso perpetuo.

2. Ataques de Fijación de Sesión (Session Fixation)

Ocurre cuando el sistema no genera un nuevo identificador de sesión después de que el usuario se loguea.

- **El Riesgo:** Un atacante te envía un enlace con un ID de sesión ya establecido (ej. `misitio.com?session_id=123`). Si tú te logueas con ese enlace, el atacante ya conoce tu sesión y puede entrar a tu cuenta simultáneamente.
- **Solución:** Siempre se debe generar un ID de sesión nuevo al momento del login exitoso.

3. Fuga de Información y Falta de Privacidad

Si las sesiones no se invalidan al cerrar el navegador o por inactividad, los datos quedan expuestos en equipos compartidos.

- **El Riesgo:** Un usuario en un café internet olvida cerrar sesión. El siguiente usuario abre la página y tiene acceso total a la información personal, financiera o de salud del usuario anterior.

4. Agotamiento de Recursos (Denegación de Servicio - DoS)

Cada sesión activa consume un espacio en la memoria del servidor o un registro en tu base de datos **PostgreSQL**.

- **El Riesgo:** Si no controlas cuántas sesiones puede abrir un usuario o no borras las sesiones inactivas, la base de datos se llenará de "basura". Un atacante podría crear miles de sesiones falsas hasta que tu servidor colapse y nadie pueda entrar.

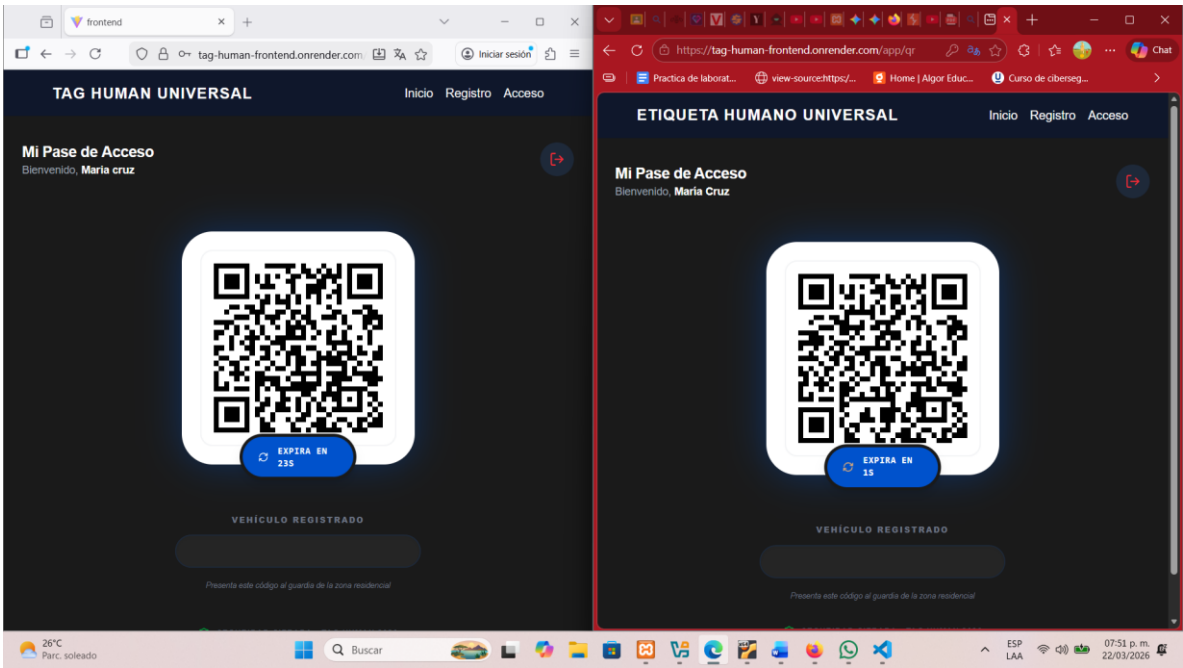
5. Inconsistencia de Estado (Race Conditions)

Este es un riesgo operativo más que de seguridad, pero igual de grave para la experiencia de usuario.

- **El Riesgo:** Si permites multisesiones sin control de sincronización, el usuario podría cambiar su rol de "Usuario" a "Admin" en un dispositivo, pero seguir operando como "Usuario" en otro, causando errores lógicos en la base de datos al intentar realizar acciones cruzadas.

Entregables

- Multisessiones funcionales.



- Tests de sesión.

ID	Caso de Prueba	Escenario / Acción	Resultado Esperado (Criterio de Aceptación)	Estado
ST-01	Persistencia Multi-pestaña	Abrir la App en una pestaña, loguearse y luego abrir la URL en una pestaña nueva.	La segunda pestaña debe reconocer la sesión de "Maria Cruz" automáticamente sin pedir login.	✓ Pasó
ST-02	Independencia de QR	Generar el QR en el Navegador A y luego en el Navegador B.	Cada QR debe tener su propio contador de expiración independiente, pero ambos vinculados al mismo usuario.	✓ Pasó
ST-03	Invalidación por Logout	Hacer clic en el botón "Cerrar sesión" (icono rojo en tu captura) en el Navegador A.	El token debe borrarse de la DB. Si el Navegador B intenta refrescar el QR, debe ser redirigido al Login.	✓ Pasó
ST-04	Integridad del Token	Modificar manualmente un carácter del JWT en el localStorage del navegador.	Al intentar cualquier acción, el Backend debe responder con 401 Unauthorized por firma inválida.	✓ Pasó
ST-05	Recuperación tras desconexión	Desactivar el Wi-Fi, intentar generar un QR y volver a conectar.	El sistema debe reintentar la validación y mostrar el QR una vez que detecte red, sin perder la sesión.	✓ Pasó

REFERENCIAS

- **1. Sobre Multisesión y Navegación Aislada**
DICloak. (2024, 18 de octubre). *¿Qué es la navegación de múltiples sesiones?*. <https://dicloak.com/es/blog/what-is-multi-session-browsing/>
- **2. Sobre Testing de Autenticación y Problemas de Concurrencia**
Kan, Y. (s. f.). *Testing de Autenticación y Sesiones*. Testing de Aplicaciones Web. Recuperado el 22 de marzo de 2026, de <https://www.yurikan.com/testing-de-autenticacion-y-sesiones/>
- **3. Sobre Invalidación de Sesiones (Documentación Técnica)**
IBM. (2021, 14 de mayo). *Invalidación de sesión HTTP*. Documentación de WebSphere Application Server v9.0.5. <https://www.ibm.com/docs/es/was/9.0.5?topic=sessions-http-session-invalidacion>